

IIT Roorkee × Futurense

PG Certificate Program in AI/GenAI Powered Cybersecurity
Capstone Project — Cohort 1

RedScope — AI-Assisted Penetration Test on a Vulnerable Lab

Field	Detail
EC-Council Track	Ethical Hacking Essentials (EHE)
Project Code	CAP-EHE-3W
Mode	Individual or Team (2–4 members)
Duration	3 weeks (~35–40 hours of effort)
Difficulty	Foundational → Intermediate (industry-aligned)
Delivery Mode	Hands-on lab + written report + oral defense
Program	PG Certificate in AI/GenAI Powered Cybersecurity, IIT Roorkee × Futurense

1. Project Overview

Students perform a structured penetration test on an instructor-provided vulnerable lab, follow PTES/OWASP methodology, use an AI assistant responsibly to accelerate recon and command discovery, and run a small adversarial-ML experiment to evade a simple ML-based defender.

2. Real-World Problem Statement

A logistics firm has just deployed an "AI-powered" intrusion detection system and a new web portal for partners. They've hired your team to (a) attempt to compromise the lab environment end-to-end and (b) specifically test whether the AI IDS can be evaded by carefully crafted traffic.

3. Key Learning Outcomes

- Apply a full pen-test methodology: scoping, recon, scanning, exploitation, post-exploitation, reporting.
- Conduct web-application testing aligned to OWASP Top 10.
- Use an AI assistant responsibly — every suggested command is reviewed before execution.
- Generate adversarial inputs against a simple ML classifier and analyze why they work.
- Produce a board-ready and a technician-ready report from the same engagement.

4. Tools and Technologies

Layer	Tools
Lab	An instructor-provided VM bundle: DVWA + OWASP Juice Shop + Metasploitable-style host
Recon / scanning	Kali Linux, Nmap, Gobuster
Web testing	Burp Suite (Community Edition)
Exploitation	sqlmap, manual SQLi/XSS, Metasploit (lab only)
Post-exploit (lab only)	Mimikatz on the lab VM only, BloodHound if AD is provided
Password	Hashcat or John
AI assistant	An LLM via API; commands are <i>suggested</i> , not executed automatically
Adversarial ML	Python, scikit-learn (build a tiny URL/payload classifier to attack)
Reporting	Markdown / PDF

5. Phased Plan — 3 Weeks

Week 1 — Plan and Recon (~12 hours)

1. Sign the Rules-of-Engagement document (scope, allowed/forbidden actions, comms plan).
2. Passive and active reconnaissance of the lab environment.
3. Vulnerability assessment with at least one scanner; deduplicate findings.

Week 1 deliverable: Signed RoE + recon report + initial finding list.

Week 2 — Exploit and Pivot (~12 hours)

1. Achieve external foothold via **one** web vulnerability (e.g., SQLi or insecure deserialization) and **one** network/service vulnerability.
2. Post-exploitation: enumerate, escalate, simulate (not exfiltrate) data movement.
3. Document the attack chain with screenshots and ATT&CK technique tags.

Week 2 deliverable: Two reproducible PoC exploits + attack-narrative timeline.

Week 3 — Adversarial ML + Reports (~14 hours)

1. Build a small ML defender (e.g., a logistic-regression classifier on web request features to detect SQLi).
2. Craft adversarial inputs that evade it; document the evasion strategy and **why** it works.
3. Write the executive report (5–7 pages, non-technical) and technical report (15–20 pages).
4. Prepare the red-team debrief.

Week 3 deliverable: Adversarial-ML experiment + executive and technical reports + debrief deck.

6. Final Deliverables

- Signed RoE.
- Attack-narrative timeline with ATT&CK technique tags.
- Two reproducible PoC exploits.
- Adversarial-ML defender + evasion write-up.
- Executive report (5–7 pages) and technical report (15–20 pages).
- Defense presentation in red-team-debrief format.

7. Evaluation Rubric

Criterion	Weight	What "Excellent" Looks Like
Methodology + OPSEC	15%	RoE followed, no out-of-scope activity, command log maintained
Web exploitation	15%	Full kill-chain documented for the web exploit
Network/post-exploit	15%	Clear escalation chain with screenshots
Responsible AI-assistant use	10%	Every accepted command justified; no blind execution
Adversarial-ML experiment	20%	Reproducible, with an honest explanation of why the evasion works
Reports (both audiences)	15%	Executive piece is genuinely readable by non-technical readers
Oral debrief	10%	Confident, accurate, ethical
Total	100%	

8. Mode: Individual vs Team Scope

Aspect	Individual	Team (2–4)
Exploits required	1 web + 1 network	2 web + 1 network
Adversarial ML	Single evasion technique	Two evasion techniques + a proposed defense
Executive report	4–5 pages	6–7 pages
Technical report	12–15 pages	18–22 pages

9. Estimated Duration

3 weeks, approximately 35–40 hours per learner.

10. Difficulty Level

Intermediate to Advanced. This is the highest-risk capstone — students must demonstrate ethical discipline and pass an RoE check before Week 2 begins.

11. Suggested Stretch Goals (Optional)

- Test whether the AI assistant (LLM) itself can be prompt-injected via crafted HTTP responses you control.
- Build a second, slightly more robust ML defender and measure how much your evasion technique degrades against it.

12. Ethics, Safety, and Responsible Use

- All offensive activity, scanning, or exploitation must be confined to the lab or instructor-provided sandbox. No real-world targets.
- Any use of GenAI / LLMs must be disclosed in the report (which model, what it was used for, how outputs were verified).
- Students must never paste real credentials, secrets, customer data, or copyrighted content into an LLM.
- All evidence and logs handled in the project remain confidential within the cohort.
- Students must sign the program's Responsible AI Use and Lab Conduct acknowledgement before starting Week 2.

13. References

- **EC-Council Essentials Series** — official module outlines and lab guides (provided via the program LMS).
- **MITRE ATT&CK** — <https://attack.mitre.org>
- **NIST Cybersecurity Framework 2.0** — <https://www.nist.gov/cyberframework>
- **OWASP Top 10** (Web / IoT / LLM) — <https://owasp.org>
- **CIS Benchmarks** — <https://www.cisecurity.org/cis-benchmarks>
- **CERT-In advisories** — <https://www.cert-in.org.in>

Prepared by the Program Office, PG Certificate in AI/GenAI Powered Cybersecurity.

IIT Roorkee × Futureense — Cohort 1
